

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN



Môn Học: Thực Tập Cơ Sở
Báo Cáo Thực Hành Bài 14
Tìm kiếm và khai thác lỗ hổng

Giảng viên:	TS. Phạm Hoàng Duy
Sinh viên:	Hoàng Anh Khoa
Mã sinh viên:	B22DCAT164
Hệ đào tạo:	Đại học chính quy

Hà Nội, 4/2025

Mục Lục

1. Mục đích	2
2. Nội dung thực hành	2
2.1. Cơ sở lý thuyết.....	2
2.1.1. Shodan.....	2
2.1.2. Google Hacking.....	4
2.2. Các bước thực hiện	5
2.2.1. Shodan.....	5
2.2.2. Thử nghiệm với google hacking.....	9
a. Danh mục: Files Containing Passwords	14
b. Danh mục: Login Pages	15
c. Danh mục: Sensitive Directories.....	15
d. Danh mục: Web Server Detection.....	16
e. Danh mục: Vulnerable Files	16
3. Kết Luận.....	17
4. Tài liệu tham khảo.....	17

Môn học Thực tập cơ sở

Bài 14: Phát hiện lỗ hổng với công cụ tìm kiếm

1. Mục đích

Bài thực hành này giúp sinh viên hiểu được mối đe dọa đến từ các công cụ tìm kiếm bao gồm Shodan và Google.

2. Nội dung thực hành

2.1. Cơ sở lý thuyết

2.1.1. Shodan

Shodan (<https://www.shodan.io/>) là một công cụ tìm kiếm được thiết kế bởi nhà phát triển web John Matherly (<http://twitter.com/achilleian>). Shodan là một công cụ tìm kiếm khác nhiều so với các công cụ tìm kiếm nội dung như Google, Yahoo hoặc Bing.

Không sử dụng cơ chế “cần lướt, sục sạo mạng web để tìm kiếm các website” như [Google](#), Shodan chỉ tập trung thăm dò các kênh sau của mạng Internet. Nói cách khác, nó giống như một Google “đen tối”, chuyên càn quét máy chủ, webcam, máy in, routers và tất cả những thứ khác, miễn là chúng có kết nối với mạng Internet.

Shodan hoạt động 24/7 và thu thập thông tin từ khoảng 500 triệu thiết bị, dịch vụ mỗi tháng.

Bạn sẽ thực sự ngỡ ngàng với những gì mình tìm thấy sau khi thực hiện một thao tác tìm kiếm đơn giản trên Shodan. Vô số đèn [giao thông](#), camera an ninh, các thiết bị tự động trong nhà hay các hệ thống sưởi nhiệt [thông minh](#) đều kết nối với Internet và có thể dễ dàng định vị giống như bóc kẹo.

Sau một thời gian dùng quen, bạn có thể tìm thấy hệ thống điều khiển của cả một công viên nước, một trạm xăng, dàn tủ ướp lạnh [rượu](#) vang của [khách sạn](#). Các nhà [nghiên cứu](#) bảo mật thậm chí còn có thể định vị hệ thống điều khiển và kiểm soát nhà mạng [điện](#) hạt nhân hay các lò gia tốc hạt thông qua Shodan.

Điều thực sự đáng nói về khả năng tìm kiếm thông tin của Shodan – cũng như tác nhân khiến cho nó trở nên thực sự đáng sợ – là rất hiếm những thiết bị mà Shodan có thể sục sạo được trang bị các hàng rào bảo mật.

“Bạn có thể đăng nhập vào khoảng một nửa mạng Internet với mật khẩu mặc định”, ông HD Moore, Giám đốc Bảo mật của Rapid 7 bình luận. “Đó là một sự thất bại [kinh hoàng](#) nhưng chưa được thừa nhận của giới bảo mật”.

Chỉ một từ khóa tìm kiếm “mật khẩu mặc định” sẽ tiết lộ vô số các thiết bị điều khiển hệ thống, máy in, máy chủ dùng “admin” làm username và “1234” làm

mật khẩu chính. Nhiều hệ thống nối mạng thậm chí còn chả có mật khẩu – tất cả những gì bạn cần là một trình duyệt web để có thể kết nối chúng.

❖ Hướng dẫn tìm kiếm

Nhập từ khóa cần tìm kiếm vào ô searchbox trên shodan. Ví dụ với từ khóa: admin/password

Kết quả trả về các máy chủ apache public, đồng thời cho bạn rất nhiều các thông tin liên quan:

- Total results: Số lượng kết quả
- Results map: Bản đồ mật độ các khu vực trên thế giới có kết quả phù hợp
- Top countries : Top các nước có số lượng tương ứng
- Top operating systems: Top các hệ điều hành sử dụng
- Top services (Ports): Top các cổng dịch vụ mở ...

Khi vào một địa chỉ IP các bạn có thêm các thông tin như: cổng đang mở, dịch vụ đang chạy, các lỗ hổng ([CVE](#)) của dịch vụ..

Để kết quả tìm kiếm chính xác hơn, các bạn có thể sử dụng thêm dấu "", kết hợp các toán tử + để có thể có nhiều hơn hoặc - để lọc bớt các kết quả không mong muốn. Ví dụ: Apache + os:windows

❖ Tìm kiếm shodan có được coi là phạm pháp?

CNN Business đã gọi Shodan là công cụ tìm kiếm đáng sợ nhất trên Internet. Từ góc độ người dùng, một công cụ tìm kiếm cung cấp những thông chi tiết và sâu và các thiết bị hay một số thông tin riêng tư. Tuy nhiên, Shodan hoàn toàn hợp pháp và không vi phạm luật. Về bản chất, shodan chỉ thu thập dữ liệu đã có sẵn trên internet và shodan chỉ đơn giản là báo cáo những gì nó tìm thấy.

❖ Tìm kiếm hiệu quả hơn với shodan

Ngoài các tìm kiếm cơ bản, để sử dụng hiệu quả shodan hơn các bạn cần biết sử dụng kết hợp các bộ lọc (filter) một cách chính xác và "thông minh". Sau đây là các bộ lọc mà các bạn có thể sử dụng kết hợp:

Các bộ lọc

Cấu trúc sử dụng filter: ***filtername:value***

- **city**: Tìm kiếm các thiết bị trong một thành phố cụ thể sử dụng mã thành phố (Ví dụ: hanoi,...)
- **country**: Tìm kiếm các thiết bị trong một quốc gia cụ thể sử dụng mã quốc gia (Ví dụ: vn, us,...)
- **hostname**: Tìm kiếm theo hostname hay domain (Ví dụ: goole, [edu.vn](#),...)

- **net**: Tìm kiếm bằng địa chỉ IP hoặc CIDR (Classless Inter-Domain Routing)
- **os**: Tìm kiếm theo hệ điều hành
- **port**: Tìm kiếm theo port cụ thể được mở
- **before/after**: Tìm kiếm trong một khoảng thời gian ...

❖ Ứng dụng shodan trong kiểm thử bảo mật

Pen Testing: Ethics

- Sử dụng shodan để xem hoặc thay đổi cấu hình các thiết bị hay server mà không yêu cầu xác thực
- Sử dụng shodan để xem hoặc thay đổi cấu hình các thiết bị hay server sử dụng tài khoản và mật khẩu mặc định
- Sử dụng shodan để xem hoặc thay đổi cấu hình của các thiết bị sử dụng chung tài khoản mật khẩu
- Sử dụng shodan để xem hoặc thay đổi cấu hình của các thiết bị bị lộ tài khoản và mật khẩu (trong cấu hình hoặc file...)

Pen Testing Applications

- Tìm kiếm để kiểm tra xâm nhập các ứng dụng trên thiết bị hay server sử dụng các yếu tố
- Mã code HTTP trả về
- Các thông tin banner, foot printing của dịch vụ
- Phiên bản của dịch vụ
- Các cổng dịch vụ đang mở

Pen Testing: HTTP Status Codes

- Tìm kiếm dựa theo phản hồi từ phía server

2.1.2. Google Hacking

Một số khái niệm cần biết

- **Google Hacking Database (GHDB)**: Đây là một cơ sở dữ liệu chứa các chuỗi truy vấn (dorks) được sử dụng để tìm kiếm các lỗ hổng bảo mật trên các trang web sử dụng Google. GHDB cung cấp các dorks đã được phân loại và được cập nhật thường xuyên, giúp người dùng tìm kiếm và khám phá các lỗ hổng bảo mật trên trang web một cách hiệu quả.
- **Google Dorks**: Google Dorks là các chuỗi truy vấn đặc biệt được sử dụng để tìm kiếm thông tin cụ thể trên Google. Bằng cách sử dụng Google Dorks, người dùng có thể tìm kiếm các tài liệu, thông tin bảo mật, thông tin người dùng, tệp đính kèm và nhiều nội dung khác mà không thể tìm thấy thông qua việc tìm kiếm thông thường.

- **Google Advanced Search:** Google Advanced Search là tính năng đặc biệt của Google cho phép người dùng tìm kiếm chính xác và rõ ràng hơn bằng cách sử dụng các tiêu chí tìm kiếm nâng cao. Với Google Advanced Search, người dùng có thể tìm kiếm đoạn văn bản cụ thể, loại tệp tin, ngôn ngữ, thời gian và vị trí, giúp lọc kết quả tìm kiếm theo yêu cầu cụ thể.
- **Google Alerts:** Google Alerts là dịch vụ của Google cho phép người dùng theo dõi các từ khóa, cụm từ hoặc tên thương hiệu trên mạng. Khi có thông tin mới liên quan đến từ khóa được theo dõi xuất hiện trên trang web, tin tức hoặc diễn đàn, người dùng sẽ nhận được thông báo qua email. Điều này giúp người dùng duy trì sự cập nhật với các tin tức và thông tin mới nhất về từ khóa quan tâm.

Có những loại thông tin nào được lưu trữ trong Google Hacking Database?

Google Hacking Database (GHD) là một tập hợp các mẫu truy vấn tìm kiếm và quy tắc để tìm kiếm các lỗ hổng bảo mật, thông tin nhạy cảm và các thông tin khác trên internet. GHD được duy trì và cập nhật bởi các chuyên gia bảo mật và là công cụ hữu ích cho người dùng muốn kiểm tra tính bảo mật của hệ thống mạng.

Trong Google Hacking Database, có nhiều loại thông tin được lưu trữ như:

- **Lỗ hổng bảo mật:** GHD cung cấp một danh sách các truy vấn tìm kiếm để tìm kiếm các hệ thống có lỗ hổng bảo mật. Ví dụ, `"inurl:admin"` sẽ tìm kiếm các trang web có đường dẫn chứa từ `"admin"`, có thể là các trang quản trị hệ thống mà không được bảo mật đầy đủ.
- **Thông tin nhạy cảm:** GHD cũng cung cấp các truy vấn để tìm kiếm thông tin nhạy cảm như thông tin tài khoản, mật khẩu, tài liệu quan trọng, email và tập tin lưu trữ. Ví dụ, `"filetype:pdf site:google.com confidential"` sẽ tìm kiếm các tập tin PDF có từ khóa `"confidential"` trên trang web `"google.com"`.
- **Các công cụ và ứng dụng hệ thống:** GHD cung cấp truy vấn để tìm kiếm các công cụ và ứng dụng đang chạy trên các máy chủ và hệ thống mạng. Ví dụ, `"intitle:index of" "Apache/2.2.14 (Ubuntu)"` sẽ tìm kiếm các trang web chạy trên máy chủ Apache/2.2.14 (Ubuntu).
- **Cấu hình mạng:** GHD cung cấp các truy vấn để tìm kiếm thông tin về cấu hình mạng như các địa chỉ IP, DNS, địa chỉ email hoặc các tập tin cấu hình mạng. Ví dụ, `"intitle:index.of etc"` sẽ tìm kiếm các tập tin cấu hình trong thư mục `/etc` trên các trang web.

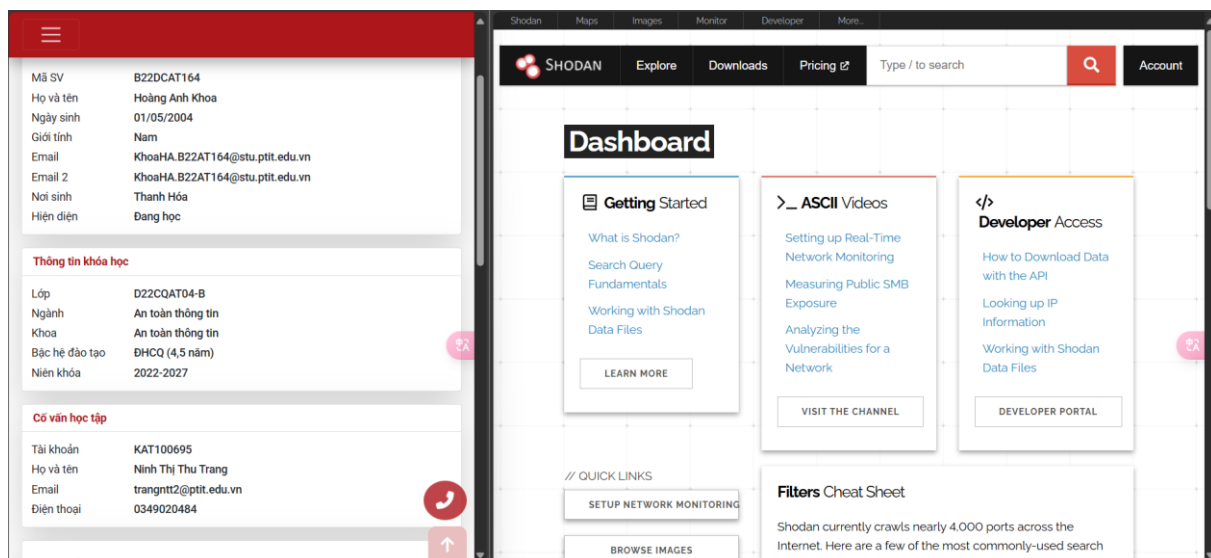
Lưu ý rằng việc sử dụng Google Hacking Database để tìm kiếm thông tin nhạy cảm hoặc tấn công vào hệ thống mà không được sự cho phép là vi phạm pháp luật và không được khuyến khích. Việc sử dụng GHD nên tuân theo các quy tắc đạo đức và tuân thủ pháp luật bảo mật thông tin.

2.2. Các bước thực hiện

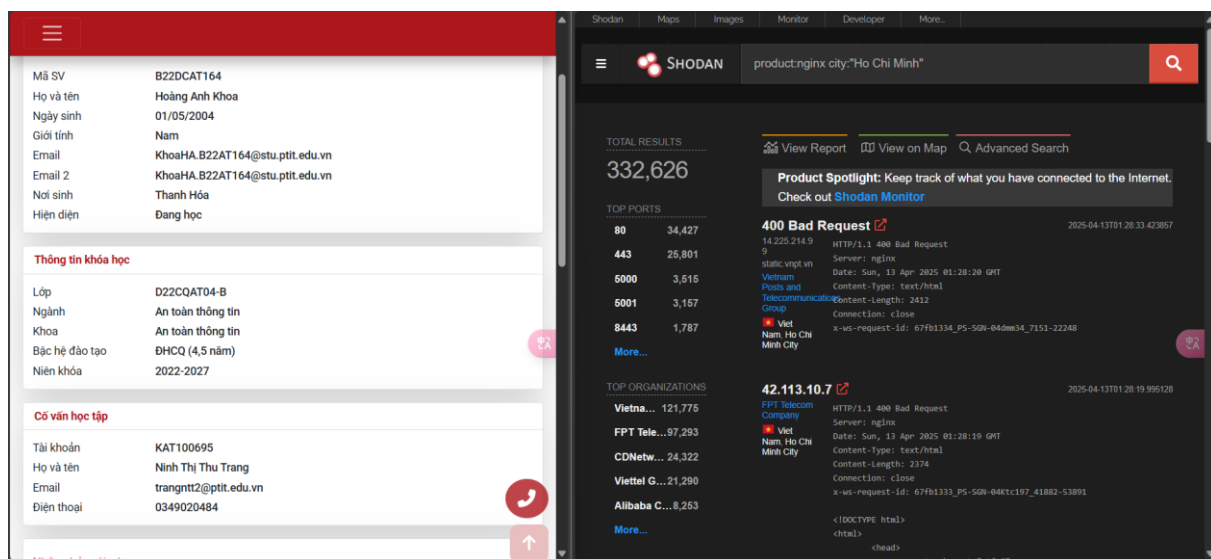
2.2.1. Shodan

a. Các bước thực hiện

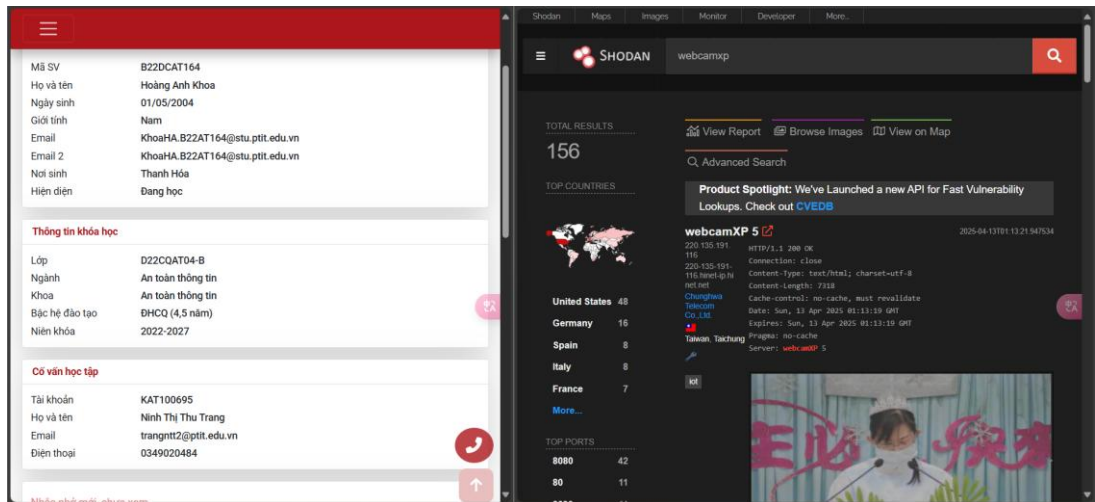
- Vào website **shodan** và tạo tài khoản, đăng nhập sử dụng



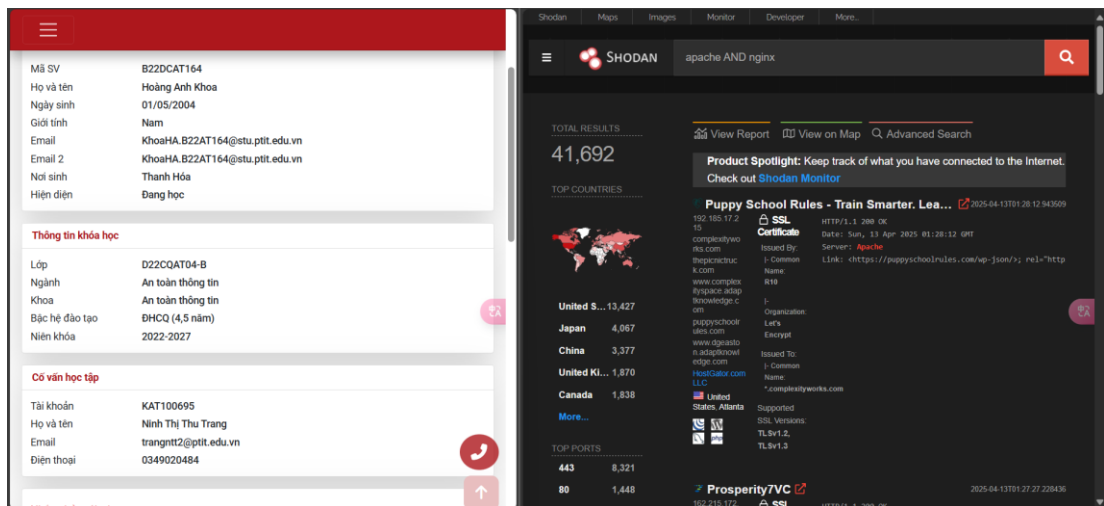
- Tìm hiểu và thử nghiệm các bộ lọc trong danh sách: <https://beta.shodan.io/search/filters>



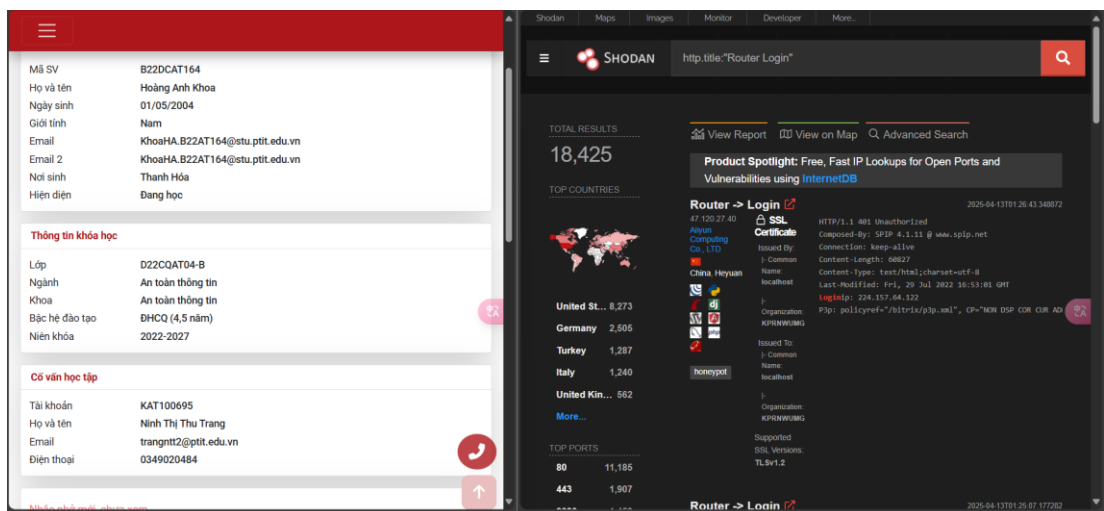
- Tìm hiểu và thử nghiệm các ví dụ trong danh sách: <https://beta.shodan.io/search/examples>



- Tìm hiểu và thử nghiệm các ví dụ trong danh sách:
<https://help.shodan.io/the-basics/search-query-fundamentals>



- Tìm hiểu và thử nghiệm các ví dụ trong danh sách:
<https://www.yeahhub.com/shodan-search-examples/>



- Tìm hiểu và thử nghiệm các ví dụ trong danh sách:
<https://www.yeahhub.com/find-vulnerable-webcams-shodan-metasploit-framework/>

```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

msf6 > search shpdan
[-] No results from search
msf6 > search shodan

Matching Modules

# Name Disclosure Date Rank C
- - - - -
0 auxiliary/admin/http/hikvision_unauth_pwd_reset_cve_2017_7921 2017-09-23 normal Y
es Hikvision IP Camera Unauthenticated Password Change Via Improper Authentication Logic
1 auxiliary/scanner/http/influxdb_enum . normal N
o InfluxDB Enum Utility
2 auxiliary/gather/prometheus_api_gather 2016-07-01 normal N
o Prometheus API Information Gather
3 auxiliary/gather/shodan_honeyscore . normal N
o Shodan Honeyscore Client
4 auxiliary/gather/shodan_host . normal N
o Shodan Host Port
5 auxiliary/gather/shodan_search . normal N
o Shodan Search
6 auxiliary/scanner/http/smt_ipmi_49152_exposure 2014-06-19 normal N
o Supermicro Onboard IPMI Port 49152 Sensitive File Exposure
7 auxiliary/gather/hikvision_info_disclosure_cve_2017_7921 2017-09-23 normal Y
es Unauthenticated information disclosure such as configuration, credentials and camera snaps
hots of a vulnerable Hikvision IP Camera
8 \_ action: Automatic . .
8 Dump all information . .
9 \_ action: Configuration . .
9
```

```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

Interact with a module by name or index. For example info 11, use 11 or use auxiliary/gather/hikvision_info_disclosure_cve_2017_7921
After interacting with a module you can manually set a ACTION with set ACTION 'Snapshot'

msf6 > auxiliary/gather/shodan_search > set SHODAN_APIKEY tFuRrv6YDms9inRZgTJWWLk1xAdfuU5
[-] Unknown command: auxiliary/gather/shodan_search. Run the help command for more details.
This is a module we can load. Do you want to use auxiliary/gather/shodan_search? [y/N] y
msf6 auxiliary(gather/shodan_search) > set SHODAN_APIKEY tFuRrv6YDms9inRZgTJWWLk1xAdfuU5
SHODAN_APIKEY => tFuRrv6YDms9inRZgTJWWLk1xAdfuU5
msf6 auxiliary(gather/shodan_search) > set QUERY webcamxp
QUERY => webcamxp
msf6 auxiliary(gather/shodan_search) > show options

Module options (auxiliary/gather/shodan_search):

Name Current Setting Required Description
-----
DATABASE false no Add search results to the database
MAXPAGE 1 yes Max amount of pages to collect
OUTFILE no A filename to store the list of IPs
QUERY webcamxp yes Keywords you want to search for
REGEX .* yes Regex search for a specific IP/City/Country/Hostname
SHODAN_APIKEY tFuRrv6YDms9inRZgTJWWLk1xAdfuU5 yes The SHODAN API key

View the full module info with the info, or info -d command.
```

```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

msf6 auxiliary(gather/shodan_search) > run

[*] Total: 148 on 2 pages. Showing: 1 page(s)
[*] Collecting data, please wait ...

Search Results

IP:Port City Country Hostname
-----
1.213.178.190:20000 Seoul Korea, Republic of
104.229.232.108:8080 Herkimer United States syn-104-229-232-108.res.spect
rum.com
108.28.226.199:8080 Gainesville United States pool-108-28-226-199.washdc.fi
os.verizon.net
109.233.191.130:8090 Belgrade Serbia ip-109-233-191-130.orienttelek
om.rs
114.32.131.232:1000 Banqiao Taiwan 114-32-131-232.hinet-ip.hinet
.net
115.22.130.117:5000 Busan Korea, Republic of
118.122.8.154:4155 Chengdu China
121.121.139.88:8086 Puchong Malaysia
121.122.127.167:8086 Puchong Malaysia
122.117.156.212:8080 Kaohsiung Taiwan 122-117-156-212.hinet-ip.hine
t.net
139.64.168.120:8080 Logan United States
14.52.200.16:8081 Seoul Korea, Republic of
160.119.231.105:9090 Johannesburg South Africa
169.0.33.30:9090 Cape Town South Africa 169-0-33-30.ip.afrihost.co.za
175.208.29.47:8087 Jeongeup Korea, Republic of
```

2.2.2. Thử nghiệm với google hacking

a) Các bước thực hiện

- Vào website www.exploit-db.com/google-hacking-database và tìm hiểu
- Nhấn vào nút **Filters** đầu bên phải của trang và mũi tên xổ menu để khai thác các mục. Các mục ở đây bao gồm **Footholds**, **Files Containing Usernames**, **Sensitive Directories**, **Web Server Detection**, và các thứ khác.

The screenshot shows the Google Hacking Database interface. On the left, there is a sidebar with user information and a 'Thông tin khóa học' (Course Information) section. The main area displays a list of search results with columns for Date Added, Dork, Category, and Author. A dropdown menu for 'Category' is open, showing options like Footholds, Files Containing Usernames, Sensitive Directories, Web Server Detection, Vulnerable Files, and Vulnerable Servers. The 'Filters' button is highlighted in orange.

Date Added	Dork	Category	Author
2024-08-23	site:github.com "BEGIN OPENSSSH PRIVATE KEY"	Files Containing Passwords	kstrawn0
2024-08-23	extnix "BEGIN OPENSSSH PRIVATE KEY"	Files Containing Passwords	kstrawn0
2024-07-26	inurl:home.htm intitle:1766	Various Online Devices	Kishoreram
2024-07-04	intitle:"SSL Network Extender Login" -checkpoint.com	Vulnerable Servers	Everton Hydd3n
2024-07-04	intext:"siemens" & inurl:"portal/portal.mwsl"	Vulnerable Servers	Kishoreram
2024-07-04	Google Dork Submission For GlobalProtect Portal	Vulnerable Servers	Gurudatt Choudhary
2024-07-04	inurl:"cgi-bin/koha"	Vulnerable Servers	Hilary Soita

- Chọn một mục để hiện ra trang thông tin có liên quan bao gồm thông tin tác giả, mô tả về tìm kiếm và các thông tin khác.

The screenshot shows a detailed view of a search result from the Google Hacking Database. The main area displays a list of search results with columns for Date Added, Dork, Category, and Author. The 'Sensitive Directories' category is selected. The 'Filters' button is highlighted in orange. The sidebar on the right contains user information and a 'Thông tin khóa học' (Course Information) section.

Date Added	Dork	Category	Author
2024-03-25	intitle: index of ./concrete/Password	Sensitive Directories	Gautam Rawat
2024-01-23	intitle:"index of" database.properties	Sensitive Directories	Odela Rohith
2022-08-17	intitle:index of "/venv"	Sensitive Directories	Abhishek Singh
2022-06-17	intitle:index of "pyvenv.cfg"	Sensitive Directories	Devanshi Gajjar
2022-06-16	site:com intitle:index ofetcpasswd	Sensitive Directories	Supriyo Guha
2022-06-15	intitle:"index of /" "sqlite.db"	Sensitive Directories	Luc Moreau
2021-11-01	intitle:"index of" ".env"	Sensitive Directories	Chinmay Divekar
2021-10-13	intitle:"index of" "/Invoices"	Sensitive Directories	AFFAN AHMED
2021-10-06	intitle: "index of backup.xml"	Sensitive Directories	Naman Shah

intitle:"index of" database.properties

GHDB- ID: 8394

Author: ODELA ROHITH

Published: 2024-01-23

Google Dork Description:

intitle:"index of" database.properties

Google Search: intitle:"index of" database.properties

Google Dork: intitle:"index of" database.properties

Description:- This page contains various database.properties of spring MVC,

Author: Odela Rohith

Date: 28-DEC-2023

LinkedIn: <https://www.linkedin.com/in/odela-rohith-b723a7122/>

Facebook: <https://www.facebook.com/odela.rohith.7>

Regards,

odela Rohith

Mã SV: B22DCAT164

Họ và tên: Hoàng Anh Khoa

Ngày sinh: 01/05/2004

Giới tính: Nam

Email: KhoaHA.B22AT164@stu.ptit.edu.vn

Email 2: KhoaHA.B22AT164@stu.ptit.edu.vn

Nơi sinh: Thanh Hóa

Hiện diện: Đang học

Thông tin khóa học

Lớp: D22CQAT04-B

Ngành: An toàn thông tin

Khoa: An toàn thông tin

Bậc hệ đào tạo: ĐHCQ (4,5 năm)

Niên khóa: 2022-2027

Cố vấn học tập

Tài khoản: KAT100695

Họ và tên: Ninh Thị Thu Trang

Email: trangntt2@ptit.edu.vn

Điện thoại: 0349020484

- Thử nghiệm với ví dụ: www.exploit-db.com/ghdb/4057. Với truy vấn tìm kiếm intitle: "Index of" "DCIM", Google sẽ trả về kết quả của các bộ sưu tập ảnh mà mọi người không biết ở đó. Sinh viên cần tìm hiểu các từ khóa trong câu lệnh: intitle, DCIM.

EXPLOIT DATABASE

intitle:"Index of" "DCIM"

GHDB- ID: 4057

Author: ANONYMOUS

Published: 2015-08-19

Google Dork Description:

intitle:"Index of" "DCIM"

Google Search: intitle:"Index of" "DCIM"

A lot of Camera Photos Dump.

Have Fun!.

Rootkit.

Mã SV: B22DCAT164

Họ và tên: Hoàng Anh Khoa

Ngày sinh: 01/05/2004

Giới tính: Nam

Email: KhoaHA.B22AT164@stu.ptit.edu.vn

Email 2: KhoaHA.B22AT164@stu.ptit.edu.vn

Nơi sinh: Thanh Hóa

Hiện diện: Đang học

Thông tin khóa học

Lớp: D22CQAT04-B

Ngành: An toàn thông tin

Khoa: An toàn thông tin

Bậc hệ đào tạo: ĐHCQ (4,5 năm)

Niên khóa: 2022-2027

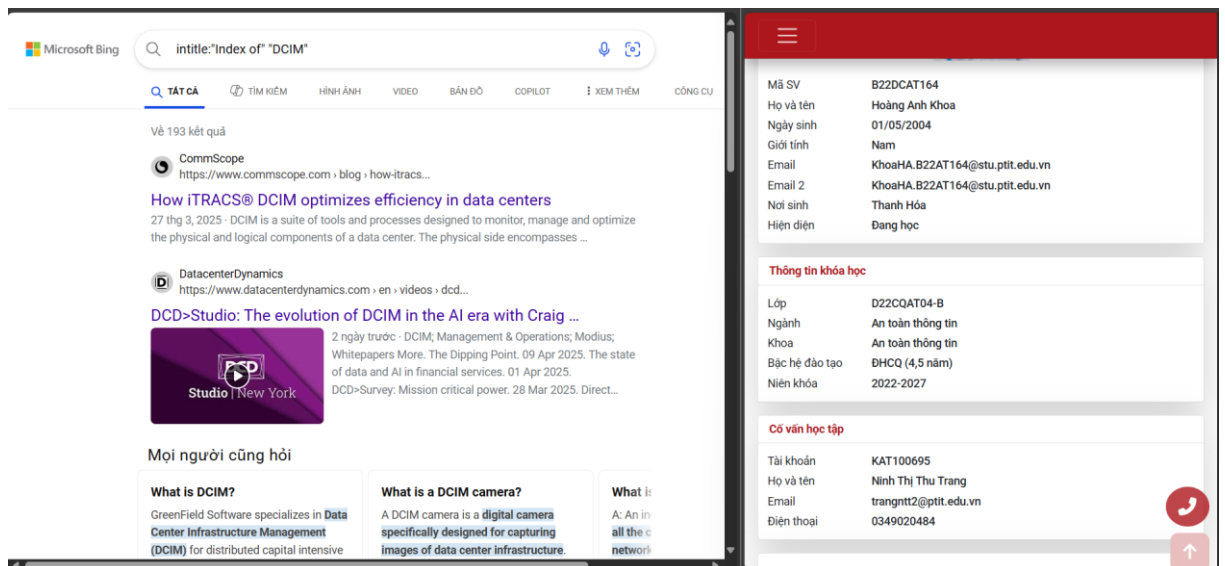
Cố vấn học tập

Tài khoản: KAT100695

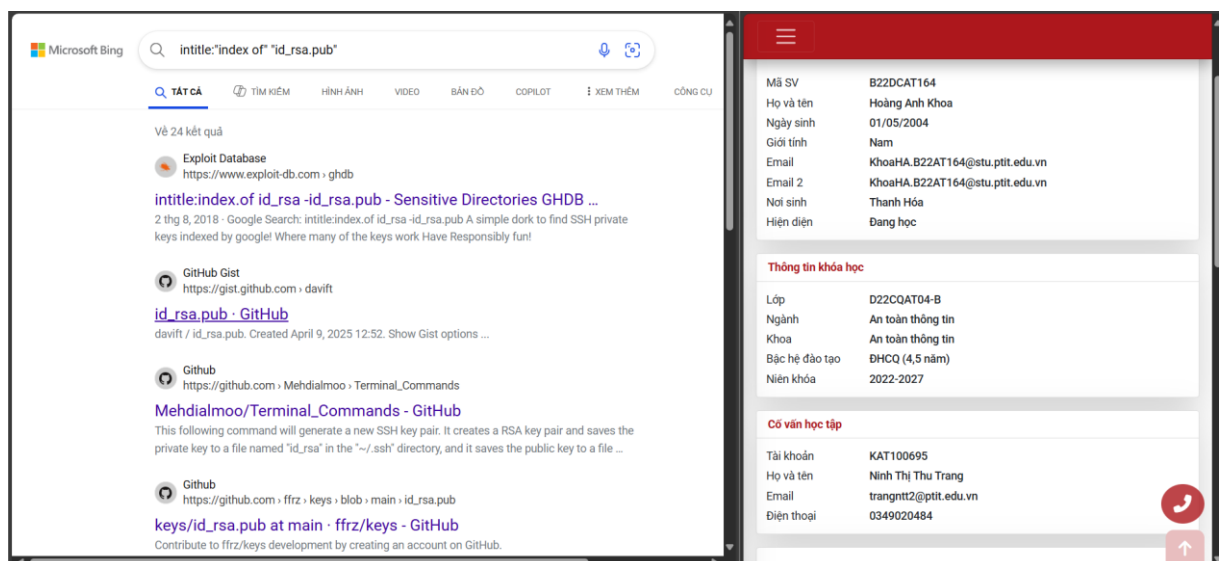
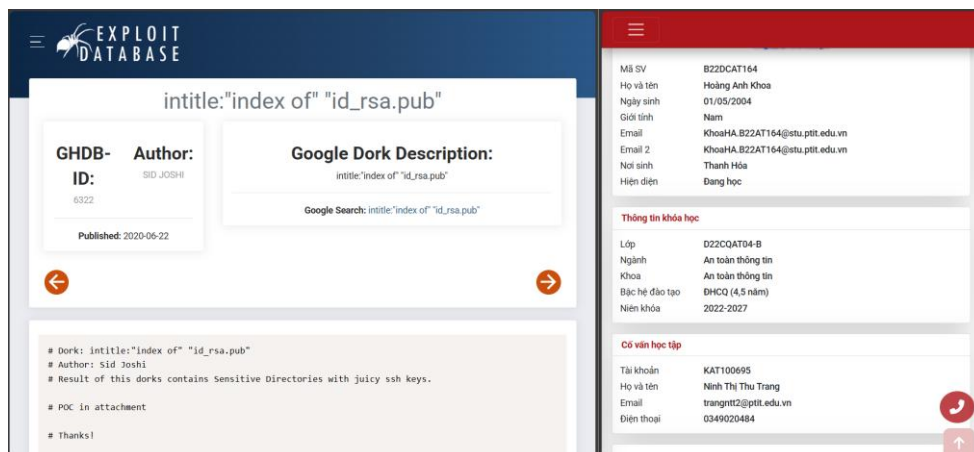
Họ và tên: Ninh Thị Thu Trang

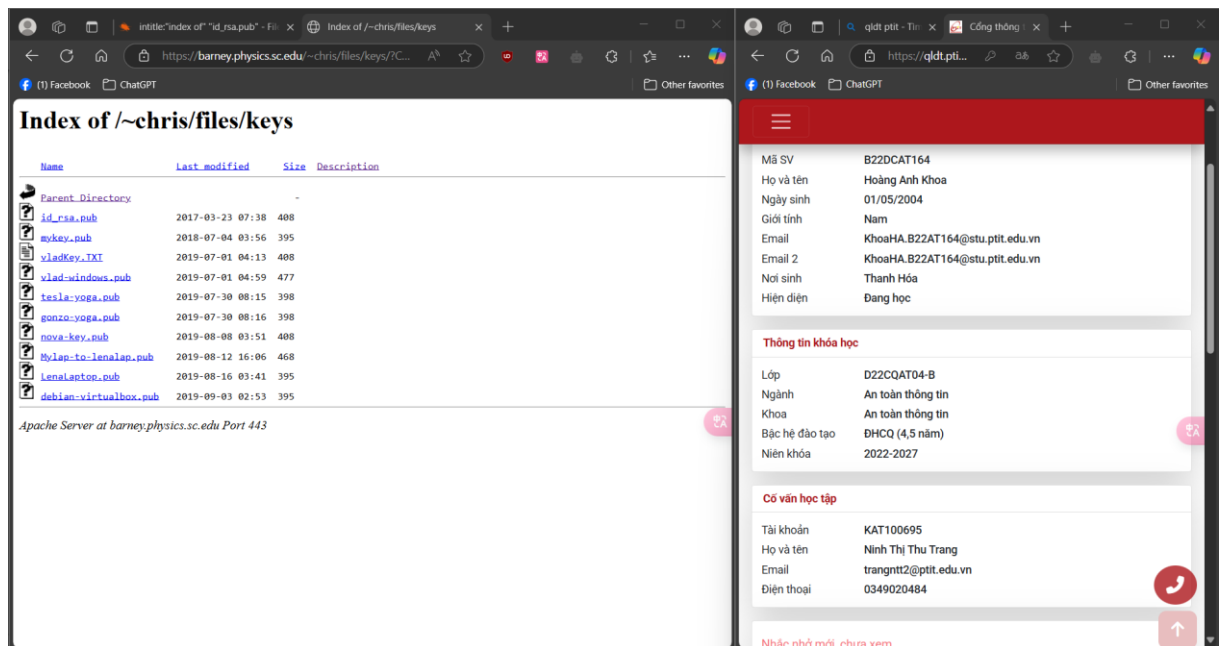
Email: trangntt2@ptit.edu.vn

Điện thoại: 0349020484

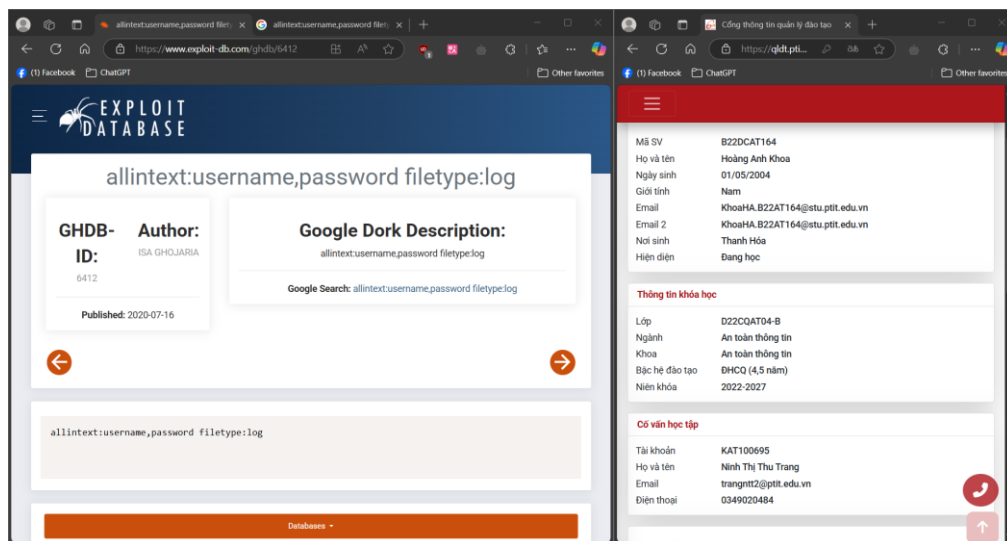


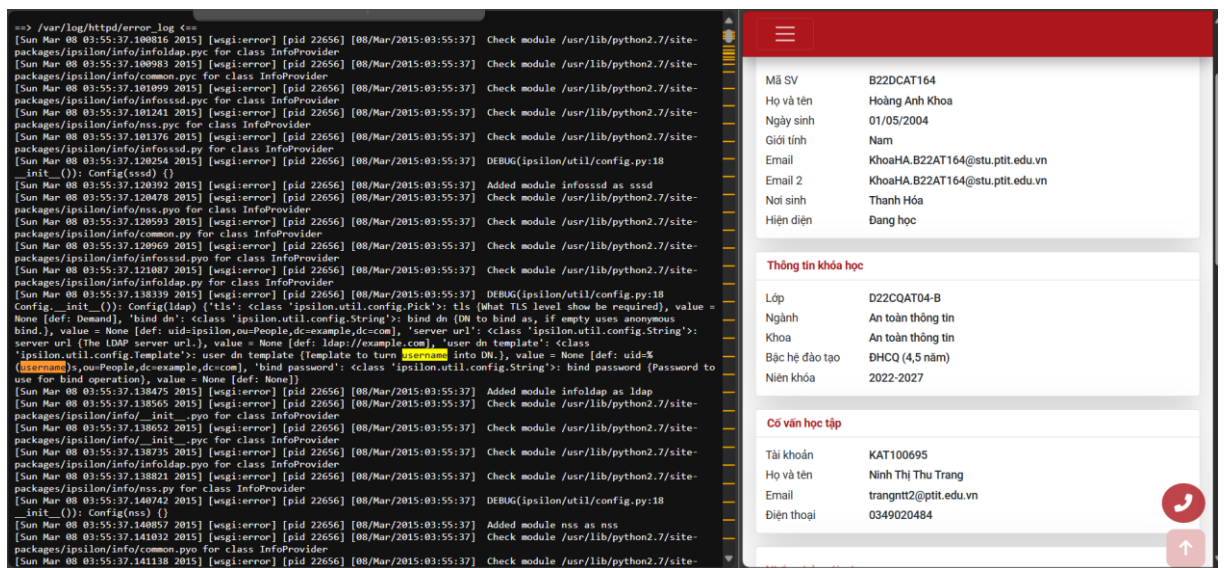
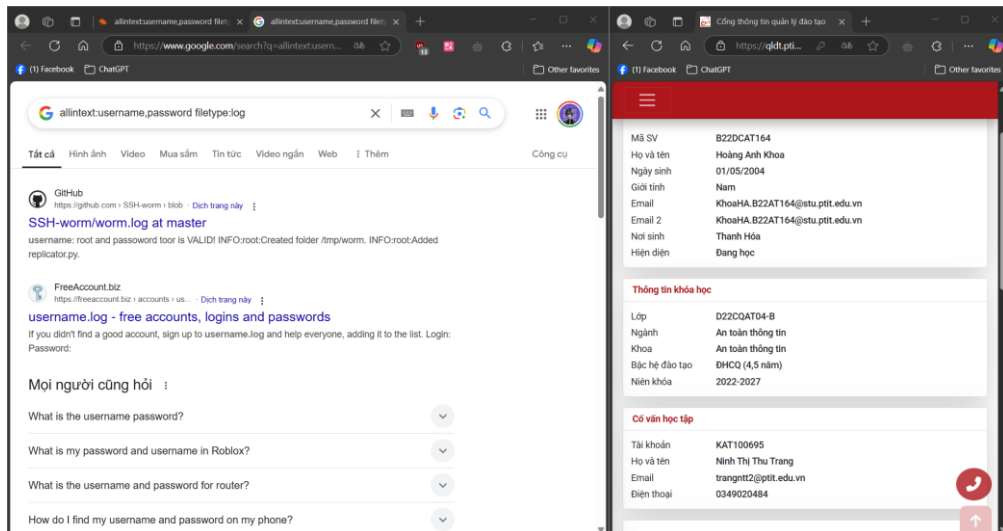
- Tìm hiểu lệnh (còn gọi là Google dork) tại www.exploit-db.com/ghdb/6322 để tìm các khóa SSH.





- Tìm hiểu Google dork tại www.exploit-db.com/ghdb/6412 tìm log có tên người dùng và mật khẩu, có thể có các mục khác như địa chỉ e-mail, URL mà những thông tin đăng nhập này được sử dụng, v.v.





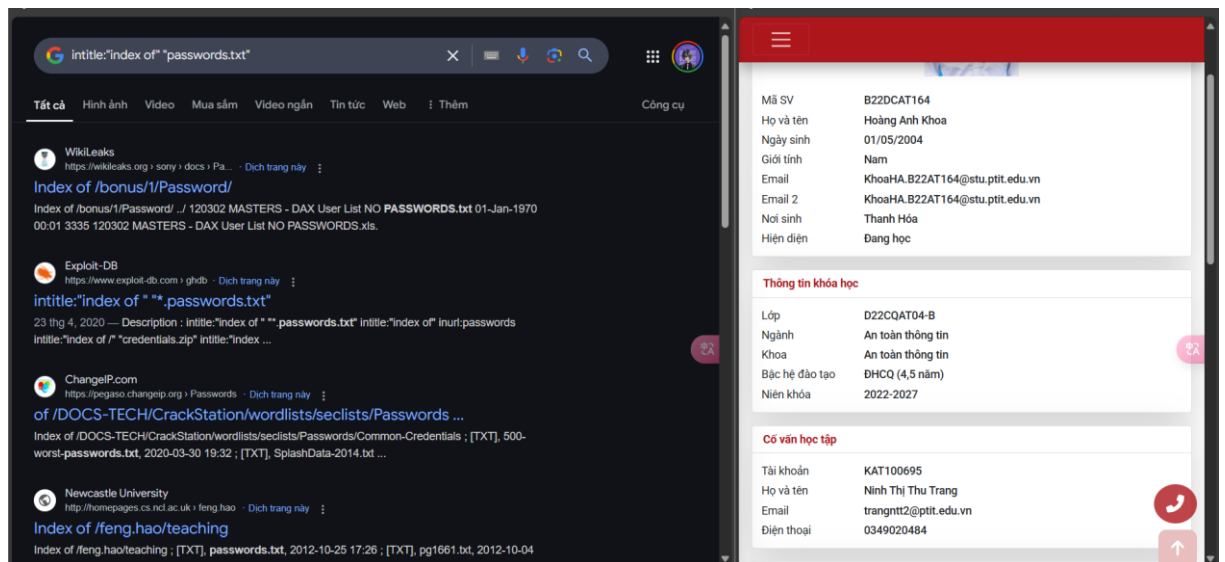
- Quay lại GHDB (www.exploit-db.com/google-hacking-database) và trong hộp văn bản **Tìm kiếm nhanh** ở bên phải, nhập FTP. Xuất hiện rất nhiều Google dorks liên quan đến Giao thức truyền tệp (FTP).

The screenshot shows the Exploit Database search results for the query 'ftp'. The results table lists several exploits, including 'CrushFTP < 11.1.0 - Directory Traversal', 'PCMan FTP Server 2.0 - 'pwd' Remote Buffer Overflow', and 'Freefloat FTP Server 1.0 - 'PWD' Remote Buffer Overflow'. On the right sidebar, there is a profile for a user named Hoàng Anh Khoa, including their student ID (B22DCAT164), email (KhoaHA.B22AT164@stu.ptit.edu.vn), and other details.

- Chọn 5 **Google dork**, mỗi loại thuộc **một danh mục khác nhau** và giải thích cách chúng có thể có nguy hiểm như thế nào. **Theo tùy chọn**, hãy nhấp vào siêu liên kết cho các dork thực tế của Google để xem kết quả nào được trả về.

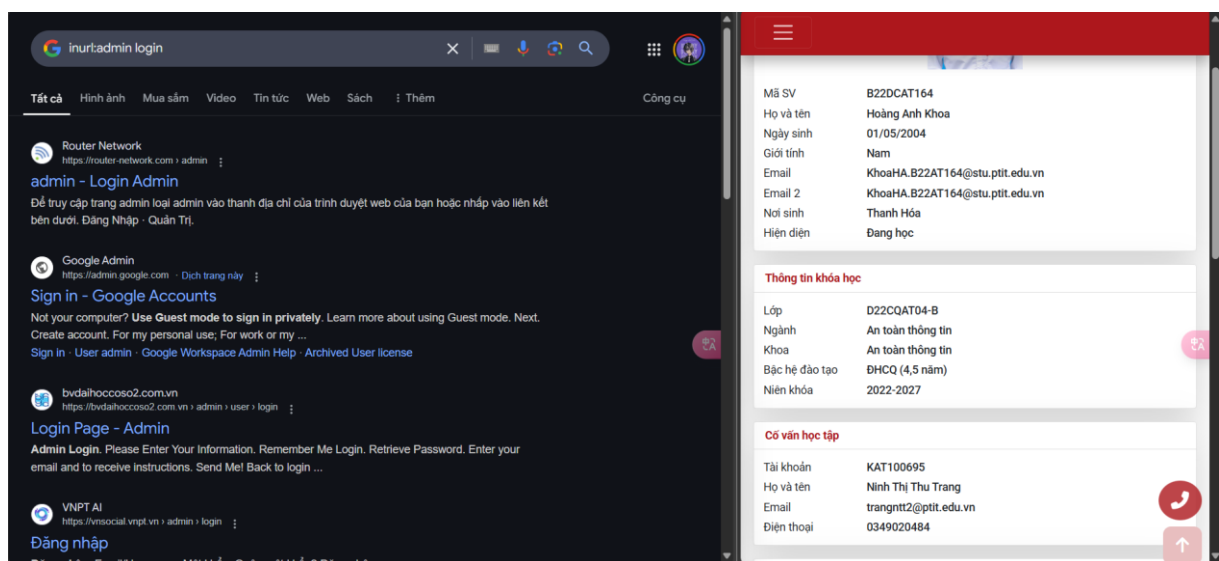
a. Danh mục: Files Containing Passwords

- **Dork:** `intitle:"index of" "passwords.txt"`
- **Nguy hiểm:** Truy vấn này tìm các thư mục không được bảo vệ, chứa file văn bản có thể chứa mật khẩu dưới dạng plaintext. Tin tặc có thể truy cập và lấy thông tin đăng nhập.



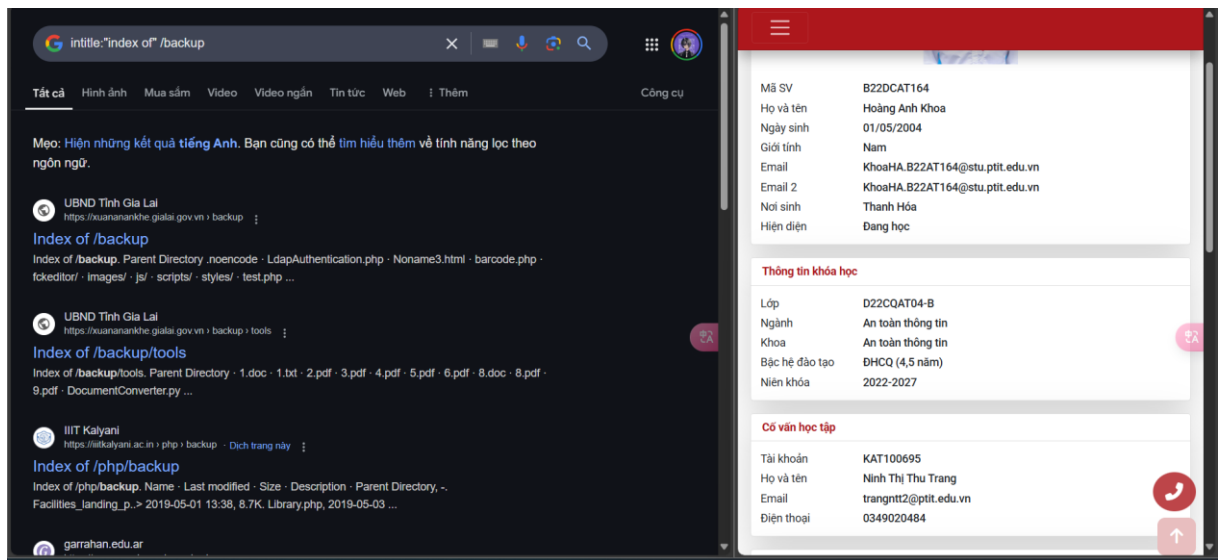
b. Danh mục: Login Pages

- **Dork:** `inurl:admin login`
- **Nguy hiểm:** Truy vấn giúp tìm ra các trang đăng nhập quản trị viên. Hacker có thể dùng brute force hoặc exploit nếu biết lỗ hổng ở phiên bản phần mềm.



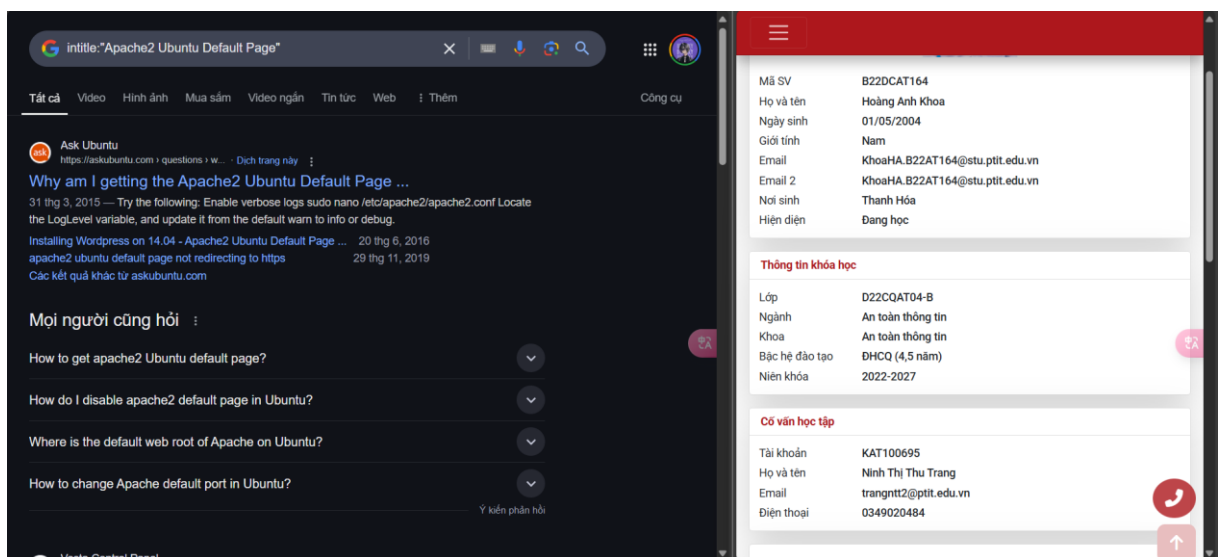
c. Danh mục: Sensitive Directories

- **Dork:** `intitle:"index of" /backup`
- **Nguy hiểm:** Tìm thấy các thư mục sao lưu chưa được bảo vệ có thể chứa source code, cơ sở dữ liệu hoặc thông tin nội bộ nhạy cảm.



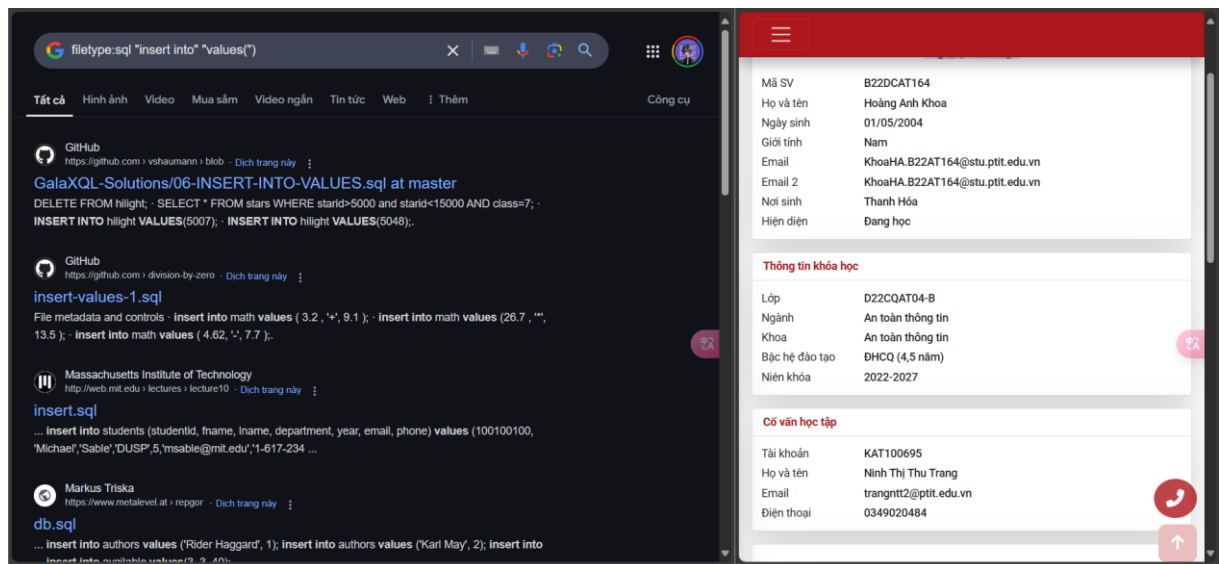
d. Danh mục: Web Server Detection

- **Dork:** intitle:"Apache2 Ubuntu Default Page"
- **Nguy hiểm:** Cho biết máy chủ web đang chạy Apache trên Ubuntu và có thể chưa cấu hình xong. Tin tặc có thể tìm cách exploit nếu server có lỗ hổng.



e. Danh mục: Vulnerable Files

- **Dork:** filetype:sql "insert into" "values("
- **Nguy hiểm:** Truy vấn này có thể trả về các file SQL chứa dữ liệu nhạy cảm như bảng user, email, mật khẩu. Tin tặc có thể dùng để khai thác thông tin cơ sở dữ liệu.



3. Kết Luận

- Lý thuyết về Shodan, Google Hacking
- Thử nghiệm thành công 10 ví dụ tìm kiếm trong shodan để tìm kiếm các lỗ hổng, các thiết bị hay dịch vụ, sử dụng các bộ lọc đã tìm hiểu bên trên.
- Thử nghiệm thành công 10 ví dụ Google hacking như đã tìm hiểu bên trên.

4. Tài liệu tham khảo

- [1]. Shodan: [shodan là gì, hướng dẫn sử dụng shodan](#)
- [2]. Google Hacking: [Kiến thức về Google Hacking](#)
- [3]. Tìm hiểu về shodan và google hack
<https://money.cnn.com/gallery/technology/security/2013/05/01/shodan-most-dangerous-internet-searches/index.html>
- [4]. Principles of Computer Security: CompTIA Security+ and Beyond